

Security+ 1.2 · Gap Analysis

Mestre CyberSec · Aula 1.2 — Gap Analysis (6:44) · [Assistir Vídeo no YouTube](#) · Treino Interativo: edusouzamarques.github.io/cybersec

Resumo Executivo da Aula: Análise de lacuna: compara o estado atual (o que tens) vs o desejado (NIST CSF, ISO 27001). A GAP = o que falta. Alimenta o roteiro de melhoria.

💡 Highlights que a prova CompTIA cobra

- Gap analysis alimenta o risk register
- É a PRIMEIRA etapa de implementação de framework

🎯 Dicas de Prova & Cenários Típicos da Banca

- A prova: 'organization checks its security posture against NIST CSF' = gap analysis

Por que este aprofundamento é cobrado na prova?: O vídeo resume os tópicos práticos, mas o exame CompTIA SY0-701 cobra discernimento técnico rigoroso sobre as tecnologias e protocolos específicos desta seção:

• Análise de Lacunas (N/A)

Processo que compara o estado atual de segurança da organização com um framework, norma ou estado desejado para identificar controles ausentes e deficiências. No Security+, é a primeira etapa ao implementar um framework e alimenta o registro de riscos e o roteiro de melhoria.

⚠ Armadilha CompTIA: Se a questão diz que a organização verifica sua postura de segurança contra o NIST CSF/ISO 27001, a resposta é gap analysis. Não confunda com risk assessment; gap analysis foca no que falta para atingir o estado desejado.

• Estado Atual (AS-IS)

A postura de segurança, controles, processos e capacidades existentes documentados de uma organização antes das melhorias. É o lado de linha de base de uma análise de lacunas.

⚠ Armadilha CompTIA: A prova pode chamar de 'what you have today' ou 'existing security posture'. É comparado ao estado desejado para calcular a lacuna.

• Estado Desejado / Estado Alvo (TO-BE)

O estado futuro de segurança definido por um framework, norma, regulamentação ou objetivo de negócio escolhido, usado como referência para comparar o estado atual. A lacuna é a diferença entre TO-BE e AS-IS.

⚠ Armadilha CompTIA: Se a questão menciona NIST CSF, ISO 27001 ou um objetivo de conformidade como referência, isso é o estado desejado. A lacuna é o que falta para chegar lá.

• Framework de Cibersegurança do NIST (NIST CSF)

Um framework voluntário de padrões, diretrizes e melhores práticas para gerenciar risco de cibersegurança, organizado em funções como Identificar, Proteger, Detectar, Responder e Recuperar. É frequentemente usado como estado desejado em análise de lacunas.

⚠ Armadilha CompTIA: Gatilho: 'checks its security posture against NIST CSF' = gap analysis. Memorize as cinco funções principais: Identify, Protect, Detect, Respond, Recover.

• ISO/IEC 27001 (ISO 27001)

Uma norma internacional para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão de segurança da informação (SGSI). Fornece um conjunto certificável de requisitos frequentemente usado como estado desejado em análise de lacunas.

⚠ Armadilha CompTIA: Se a questão cita ISO 27001 como benchmark de conformidade, a organização está fazendo gap analysis contra um estado desejado. Não confunda ISO 27001 (requisitos do ISMS) com ISO 27002 (controles).

• Registro de Riscos (N/A)

Uma lista documentada de riscos identificados, incluindo proprietário do risco, probabilidade, impacto e status de mitigação. Os achados da análise de lacunas frequentemente alimentam o registro de riscos para que controles ausentes se tornem riscos rastreados.

⚠ Armadilha CompTIA: Lembre: gap analysis alimenta o risk register. Se a questão pergunta onde as lacunas são documentadas para tratamento, a resposta pode ser risk register.

• Roteiro de Remediação (N/A)

Um plano priorizado que lista ações, responsáveis, prazos e recursos necessários para fechar as lacunas identificadas por uma análise de lacunas. Transforma achados em um plano de melhoria acionável.

⚠ Armadilha CompTIA: A saída da gap analysis é o roteiro de melhoria/remediação. Se a questão pergunta o próximo passo após identificar lacunas, procure plano priorizado de correção.

• Postura de Segurança (N/A)

O status geral de segurança dos sistemas, redes e dados de uma organização com base nos controles, políticas e configurações implementados. A análise de lacunas compara a postura de segurança atual com um alvo desejado.

⚠ **Armadilha CompTIA:** Expressão comum na prova: 'organization checks its security posture against [framework]' = gap analysis. Não é um scanner de vulnerabilidades; é uma comparação estratégica de estado atual vs desejado.

✅ Perguntas de Treino Comentadas (10 Questões de Cenários Reais)

Cenários autênticos alinhados aos objetivos do exame. O gabarito com análise completa dos distratores encontra-se ao final.

QUESTÃO 1 · CENÁRIO DE EXAME

Uma empresa de serviços financeiros documentou suas políticas de segurança, controles de acesso e processos de monitoramento existentes. Antes de adotar a ISO/IEC 27001, o CISO pede à equipe que compare as práticas atuais com os requisitos de controle da norma para identificar o que está faltando. Qual atividade a equipe está realizando?

- A) Análise de impacto nos negócios
- B) Teste de penetração
- C) Análise de lacunas
- D) Avaliação de vulnerabilidades

QUESTÃO 2 · CENÁRIO DE EXAME

Após concluir os perfis de estado atual e estado desejado usando o NIST Cybersecurity Framework, uma empresa de varejo identifica várias deficiências de controle em detecção e resposta. A liderança quer um plano priorizado que atribua responsáveis, prazos e marcos para fechar essas deficiências. Qual artefato deve ser criado?

- A) Registro de riscos
- B) Playbook de resposta a incidentes
- C) Roteiro de remediação
- D) Inventário de ativos

QUESTÃO 3 · CENÁRIO DE EXAME

Uma organização de saúde realiza uma análise de lacunas em relação ao NIST CSF e descobre que vários controles estão ausentes. O gerente de segurança registra cada deficiência, sua probabilidade, impacto potencial, responsável e tratamento planejado. Onde essas informações devem ser mantidas principalmente?

- A) Registro de gerenciamento de mudanças
- B) Registro de riscos
- C) Plano de continuidade de negócios
- D) Portal de conscientização de segurança

QUESTÃO 4 · CENÁRIO DE EXAME

Uma fabricante multinacional quer que seu sistema de gestão de segurança da informação seja certificado de forma independente contra uma norma reconhecida internacionalmente. A equipe de segurança deve escolher um estado desejado que inclua requisitos de sistema de gestão e controles do Anexo A. Qual framework é mais apropriado?

- A) NIST Cybersecurity Framework
- B) ISO/IEC 27001
- C) PCI DSS
- D) CIS Critical Security Controls

QUESTÃO 5 · CENÁRIO DE EXAME

Um governo municipal deseja um framework voluntário para avaliar e melhorar a maturidade de segurança cibernética em funções como Identificar, Proteger, Detectar, Responder e Recuperar. O diretor de TI pergunta qual estado desejado estruturaria melhor essa avaliação. Qual framework deve ser selecionado?

- A) ISO/IEC 27001
- B) NIST Cybersecurity Framework
- C) GDPR
- D) COBIT

QUESTÃO 6 · CENÁRIO DE EXAME

Durante uma análise de lacunas, o avaliador documenta que a organização aplica autenticação multifator para usuários remotos de VPN, mas não para administradores que acessam dispositivos de rede. O estado desejado exige MFA para todo acesso privilegiado. Qual lacuna foi identificada?

- A) Usuários remotos de VPN não são obrigados a usar MFA
- B) O acesso administrativo a dispositivos de rede não possui MFA
- C) Dispositivos de rede não estão inventariados
- D) Contas privilegiadas não são registradas em log

QUESTÃO 7 · CENÁRIO DE EXAME

Uma análise de lacunas em relação aos CIS Controls mostra vinte salvaguardas ausentes, mas a empresa tem verba para apenas cinco neste trimestre. O CISO quer reduzir primeiro o maior risco de negócios. Qual abordagem deve ser usada para selecionar os itens iniciais de remediação?

- A) Implementar salvaguardas em ordem alfabética
- B) Priorizar com base em risco, impacto nos negócios e criticidade dos ativos
- C) Escolher os cinco itens de menor custo, independentemente do risco
- D) Adiar toda a remediação até a próxima auditoria externa

QUESTÃO 8 · CENÁRIO DE EXAME

Um analista de segurança está preparando a visão AS-IS para uma análise de lacunas. A organização precisa de um registro autoritativo de hardware implantado, versões de software e linhas de base de configuração em todo o ambiente. Qual fonte é mais apropriada para essa documentação do estado atual?

- A) O relatório de teste de recuperação de desastres
- B) O banco de dados de gerenciamento de configuração e o inventário de ativos
- C) O relatório de conclusão do treinamento de conscientização de segurança
- D) O calendário de renovação de licenças de software do fornecedor

QUESTÃO 9 · CENÁRIO DE EXAME

Um gerente pergunta por que a equipe não pode usar a análise de lacunas concluída como substituta da avaliação anual de riscos. Qual afirmação explica melhor a distinção?

- A)** A análise de lacunas compara controles atuais com um estado desejado escolhido, enquanto a avaliação de riscos avalia probabilidade e impacto de ameaças e vulnerabilidades
- B)** A análise de lacunas se aplica apenas a ambientes de nuvem, enquanto a avaliação de riscos se aplica apenas a sistemas locais
- C)** A análise de lacunas identifica vulnerabilidades técnicas, enquanto a avaliação de riscos documenta apenas multas regulatórias
- D)** A análise de lacunas é realizada após incidentes, enquanto a avaliação de riscos é realizada apenas após auditorias

QUESTÃO 10 · CENÁRIO DE EXAME

Uma empresa concluiu uma análise de lacunas em relação à ISO/IEC 27001 e implementou um roteiro de remediação ao longo de nove meses. O CISO agora quer evidências de que as deficiências identificadas anteriormente foram fechadas antes da auditoria de certificação. O que a equipe de segurança deve fazer?

- A)** Executar novamente a análise de lacunas em relação ao mesmo estado desejado e revisar evidências dos controles implementados
- B)** Desativar os controles que não estavam originalmente no escopo
- C)** Substituir o registro de riscos pelo plano de resposta a incidentes
- D)** Aguardar que o auditor externo identifique quaisquer lacunas restantes sem verificação interna

GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

Questão 1: Alternativa C — Análise de lacunas

A análise de lacunas compara o estado atual, geralmente chamado AS-IS, com um estado desejado, como a ISO/IEC 27001. Seu objetivo é identificar controles, processos e capacidades ausentes ou insuficientes. Não é um teste de penetração, uma varredura de vulnerabilidades ou uma análise de impacto nos negócios, embora essas atividades possam fornecer dados.

Questão 2: Alternativa C — Roteiro de remediação

Um roteiro de remediação transforma os resultados da análise de lacunas em ações de melhoria sequenciadas. Ele normalmente inclui prioridades, responsáveis, prazos, marcos e recursos necessários para ir do estado atual ao estado desejado. Um registro de riscos acompanha riscos, um playbook de resposta a incidentes orienta atividades de resposta e um inventário de ativos lista ativos.

Questão 3: Alternativa B — Registro de riscos

Os achados da análise de lacunas geralmente alimentam o registro de riscos, que acompanha riscos com detalhes como probabilidade, impacto, responsável e plano de tratamento. Um registro de gerenciamento de mudanças acompanha alterações em sistemas, um plano de continuidade de negócios documenta estratégias de continuidade e um portal de conscientização é usado para treinamento e comunicação.

Questão 4: Alternativa B — ISO/IEC 27001

A ISO/IEC 27001 é a norma reconhecida internacionalmente para estabelecer, implementar, manter e melhorar continuamente um sistema de gestão de segurança da informação. Ela inclui requisitos de sistema de gestão e controles do Anexo A, e as organizações podem ser certificadas contra ela. O NIST CSF é voluntário, o PCI DSS foca em dados de cartões de pagamento e os CIS Controls são salvaguardas técnicas, não uma norma certificável de SGSI.

Questão 5: Alternativa B — NIST Cybersecurity Framework

O NIST Cybersecurity Framework é organizado em torno das funções principais Identificar, Proteger, Detectar, Responder e Recuperar. Ele é amplamente usado para avaliar e melhorar a maturidade de segurança cibernética. A ISO/IEC 27001 é uma norma de certificação de SGSI, o GDPR é uma regulamentação de privacidade e o COBIT é um framework de governança de TI.

Questão 6: Alternativa B — O acesso administrativo a dispositivos de rede não possui MFA

O estado atual mostra que o MFA já é aplicado para usuários remotos de VPN, mas está ausente para administradores que acessam dispositivos de rede. Como o estado desejado exige MFA para todo acesso privilegiado, a lacuna específica é a falta de MFA para acesso administrativo a dispositivos de rede. As outras opções não são sustentadas pelo cenário.

Questão 7: Alternativa B — Priorizar com base em risco, impacto nos negócios e criticidade dos ativos

A análise de lacunas identifica o que está faltando, mas a remediação deve ser priorizada usando critérios baseados em risco, como probabilidade, impacto potencial nos negócios, criticidade dos ativos e obrigações regulatórias. Ordem alfabética, menor custo isoladamente ou esperar por uma auditoria não reduzem de forma confiável o maior risco de negócios.

Questão 8: Alternativa B — O banco de dados de gerenciamento de configuração e o inventário de ativos

O banco de dados de gerenciamento de configuração e o inventário de ativos fornecem detalhes autoritativos sobre hardware implantado, versões de software e linhas de base de configuração. Esses são insumos importantes para documentar o estado atual durante uma análise de lacunas. Relatórios de teste de recuperação de desastres, relatórios de conclusão de treinamento e calendários de renovação de licenças não fornecem uma visão técnica confiável do AS-IS.

Questão 9: Alternativa A — A análise de lacunas compara controles atuais com um estado desejado escolhido, enquanto a avaliação de riscos avalia probabilidade e impacto de ameaças e vulnerabilidades

A análise de lacunas concentra-se em comparar o estado atual com um estado desejado, como NIST CSF ou ISO/IEC 27001, para identificar controles ou capacidades ausentes. A avaliação de riscos avalia ameaças, vulnerabilidades, probabilidade e impacto para determinar níveis de risco. As duas atividades são complementares, mas não intercambiáveis.

Questão 10: Alternativa A — Executar novamente a análise de lacunas em relação ao mesmo estado desejado e revisar evidências dos controles implementados

Para verificar se as lacunas identificadas anteriormente foram fechadas, a equipe deve reavaliar o estado atual em relação ao mesmo estado desejado, como a ISO/IEC 27001, e revisar evidências de que os controles foram implementados e operam efetivamente. Isso confirma o progresso da remediação antes da auditoria de certificação.